

Documentación de Seguridad y Resiliencia

Ecosistema de Automatización IA — Venta de e-books y atención de consultas

Cinthia Ávalos · Proyecto Integrador Final · IA Automation

Este documento cubre los tres pilares de resiliencia y seguridad que pide la rúbrica: qué datos personales toca el sistema y cómo se minimizan, qué pasa cuando algo falla (rutas de error), y en qué puntos el sistema se detiene a esperar una validación humana antes de ejecutar una acción crítica (HITL). Además de describir lo que ya está implementado, se señalan honestamente los puntos débiles detectados y las mejoras recomendadas para un escenario de producción real.

1. Minimización de Datos

1.1 Qué datos recolecta el sistema

El formulario de Google Forms solo pide los datos estrictamente necesarios para poder vender el e-book y responder consultas: nombre y apellido, email, el libro elegido, el consentimiento (opt-in) para recibir promociones y, opcionalmente, una consulta en texto libre. No se solicita teléfono, dirección ni ningún dato de tarjeta o cuenta bancaria del cliente — el pago se resuelve por fuera del flujo automatizado (transferencia bancaria + envío manual del comprobante), por lo que el sistema nunca almacena ni procesa datos financieros de terceros.

1.2 Dónde vive cada dato

Dato	Dónde se guarda	Necesidad / uso
Nombre, Email, Libro, Status	Airtable — tabla “Panel de control”	Registro y seguimiento del estado de cada cliente. Es el único repositorio estructurado de datos personales del sistema.
Consulta del cliente (texto libre)	Airtable — campo “Consultas” / tabla “Error Ai agent”	Necesario para que la IA responda y para auditar respuestas rechazadas. Puede incluir datos sensibles si el cliente menciona una condición de salud (ej. celiaquía); se trata como dato sensible (ver 1.3).
Nombre y Email del cliente	Descripción del evento de Google Calendar (recordatorio de pago pendiente)	Solo para identificar a quién hay que recontactar al día siguiente. Es el punto de MENOR control de acceso de todo el flujo (ver alerta más abajo).
Manual / recetario en PDF	Google Drive (fuente del RAG)	Contenido genérico del negocio, sin datos de clientes. Ningún dato de un cliente puede filtrarse a otro a través de las respuestas de la IA, porque la única fuente que lee el modelo es este manual.

Tabla 1 — Mapa de datos personales del ecosistema.

Dato sensible detectado: el campo de consulta libre puede contener información de salud del cliente (por ejemplo, si menciona ser celíaco o tener una alergia alimentaria al preguntar por un libro). Se recomienda no exponer ese campo en el enlace público del Dashboard de Control (entregable 5) y restringir el acceso de la tabla “Panel de control” solo a la dueña del negocio.

Punto débil identificado: los eventos de Google Calendar guardan el nombre y el email del cliente en texto plano dentro de la descripción. A diferencia de Airtable, un calendario de Google suele compartirse más fácilmente (por ejemplo, si en el futuro se comparte la agenda con un asistente). Mejora recomendada: reemplazar nombre/email por un identificador interno (ej. el ID de la fila de Airtable) y dejar los datos completos únicamente en la base de datos.

1.3 Minimización en el prompt de la IA

El prompt que recibe Gemini está instruido explícitamente para: (a) responder solo con información contenida en el manual del negocio, sin inventar datos fuera de esa fuente; (b) no repetir ni solicitar datos bancarios del cliente; y (c) no emitir diagnósticos ni recomendaciones de salud, aun cuando la consulta lo sugiera. Esto reduce tanto el riesgo de alucinación como la superficie de exposición de datos sensibles en las respuestas automáticas.

2. Rutas de Error (Error Handlers)

2.1 Manejo de errores del nodo de IA

El nodo “La Agent para responder consultas” (Gemini) está configurado con reintento automático (retryOnFail) y una salida de error dedicada (onError: continueErrorOutput). Esto significa que, ante una falla transitoria (por ejemplo, un timeout o un error momentáneo de la API), n8n reintenta la llamada antes de darla por perdida. Si el error persiste, el flujo no se detiene ni queda colgado: continúa por una segunda salida (la de error) en lugar de interrumpir toda la ejecución.

Esa salida de error dispara siempre la misma secuencia, sin excepción:

- Se actualiza el Status del cliente en Airtable a “ERROR”, con el detalle del error guardado en el campo Consultas.
- Se envía un email urgente al vendedor (HITL de contingencia) avisando que el nodo de IA falló y que ese caso necesita atención manual.

De esta forma ningún fallo del agente de IA queda silencioso: siempre se refleja en el panel de control y siempre se notifica a una persona.

2.2 Validación de tipos de datos en los filtros

El router “Clasificación de formulario” compara el campo Libro contra las 4 opciones reales del formulario usando comparación de texto exacta (string vs. string), con typeValidation en modo estricto y sensibilidad a mayúsculas. Esto evita el error típico de comparar tipos de datos distintos (por ejemplo, un número contra un texto) que haría que una condición nunca se cumpliera de forma silenciosa.

Por qué no hace falta una salida de “fallback” acá: el campo Libro del formulario es de opción múltiple y de respuesta obligatoria, con las 4 opciones fijas ya redactadas exactamente igual a las condiciones del switch (mismo texto, mismos emojis). Google Forms no deja enviar el formulario sin marcar una opción, y no permite escribir un valor distinto a esas 4. Es decir, el margen de error que normalmente justificaría una quinta salida de fallback ya está cerrado en el origen del dato, antes de que llegue al switch: no puede llegar vacío ni con un valor inesperado. Un fallback seguiría siendo una buena práctica defensiva general, pero en este caso puntual no está cerrando ningún hueco real — es una capa de seguridad redundante, no un fix a un problema existente.

2.3 Prevención de bucles infinitos

El trigger revisa la hoja de Google Sheets cada un minuto (polling), y el alta en Airtable se hace en modo “upsert” usando el Email como columna de coincidencia: si el mismo cliente vuelve a aparecer, se actualiza su fila existente en lugar de crear una nueva o volver a disparar todo el proceso desde cero. Ningún nodo del flujo escribe de vuelta en la

hoja de Google Sheets que dispara el trigger, por lo que no existe un camino donde el propio flujo genere el evento que lo vuelve a disparar a sí mismo — condición necesaria para un bucle infinito.

2.4 Alcance actual del manejo de errores

Punto a mejorar: hoy el único nodo con manejo de error dedicado es el agente de IA. No hay un workflow de error global de n8n (Error Trigger) que capture fallas de otros nodos críticos, como Airtable, Gmail o Google Calendar, si por ejemplo se cae momentáneamente alguna de esas APIs. Para un escenario de producción se recomienda agregar un workflow de error general que envíe una alerta equivalente ante cualquier falla, no solo las del nodo de IA.

3. Puntos de Human-in-the-loop (HITL)

El sistema tiene dos puntos donde se detiene completamente y espera una decisión humana antes de seguir con una acción crítica. Los dos usan el mismo mecanismo técnico: un nodo de Gmail en modo “send and wait for response”, que pausa la ejecución del workflow hasta recibir la respuesta del vendedor (en este caso, la propia dueña del negocio).

Punto de HITL	Acción crítica que protege	Qué pasa si se aprueba	Qué pasa si se rechaza
Confirmación de pago	Entregar un producto pago (el e-book) sin haber verificado el cobro	Se envía el link del e-book al cliente y el estado pasa a “Venta completada”	Se pide comprobante de pago al cliente, el estado pasa a “Revisar banco nuevamente” y se agenda un recordatorio en el calendario para el día siguiente
Aprobación de la respuesta de la IA	Enviar al cliente una respuesta generada por IA sin revisión (riesgo de alucinación o tono inadecuado)	La respuesta se envía al cliente por email tal como la aprobó el vendedor	La respuesta no se envía; se guarda en la tabla “Error Ai agent” para ajustar el prompt más adelante

Tabla 2 — Los dos puntos de validación humana del flujo.

En el contexto real del negocio (un emprendimiento unipersonal), estos dos puntos no son solo un requisito de la consigna: son el control de calidad real de la operación. Al ser la propia dueña quien aprueba cada venta y cada respuesta antes de que salga hacia el cliente, ninguna acción irreversible (cobrar sin verificar, o contestar algo incorrecto en su nombre) ocurre sin supervisión humana directa.

4. Resumen

- Minimización de datos: se recolecta lo mínimo indispensable, no se tocan datos bancarios de clientes, y se identificaron dos puntos de exposición a mejorar (campo de consulta como dato sensible, y datos personales en la descripción del evento de calendario).
- Rutas de error: el nodo de IA reintenta automáticamente y, si falla, siempre deja rastro en Airtable y avisa por email. El router de clasificación no necesita una salida de fallback porque el propio formulario (campo obligatorio, opción múltiple) ya impide que llegue un valor vacío o inesperado; queda pendiente como mejora agregar un workflow de error global de n8n que cubra fallas de Airtable, Gmail o Google Calendar.
- Human-in-the-loop: dos puntos de parada obligatoria (pago y respuesta de IA) antes de cualquier acción irreversible hacia el cliente.